Risk Management

Ref: Corporate Computer Security, 4th Edition, Global Edition

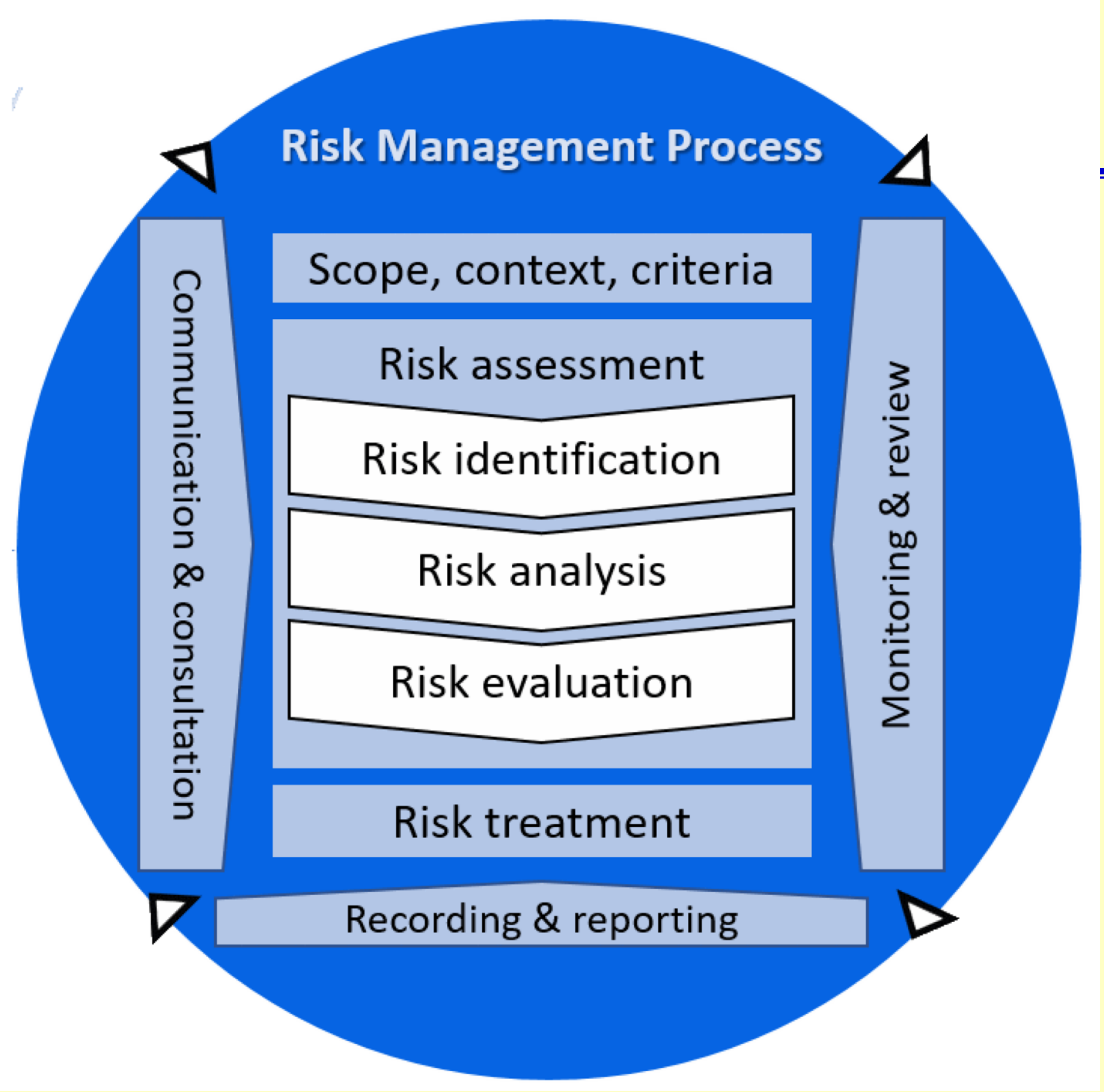
Randall J. Boyle & Raymond R. Panko

Outline

- Risk Management
- Assets
- Threat
- Impact
- Probability

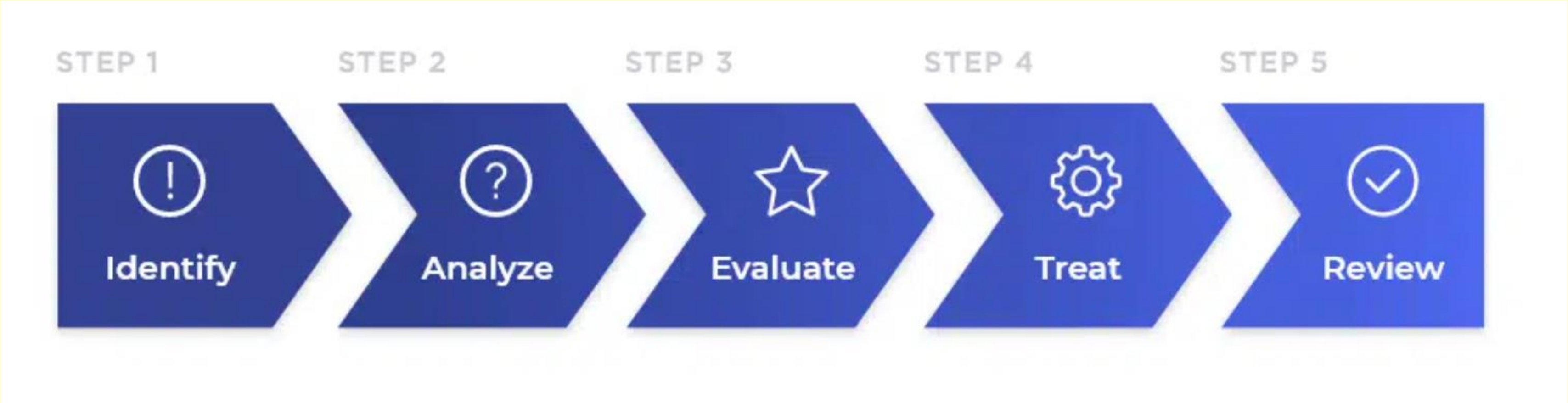
Risk Management

- Risk Identification
- Risk Analysis
- Risk Assessment
- Risk Control
- Monitoring



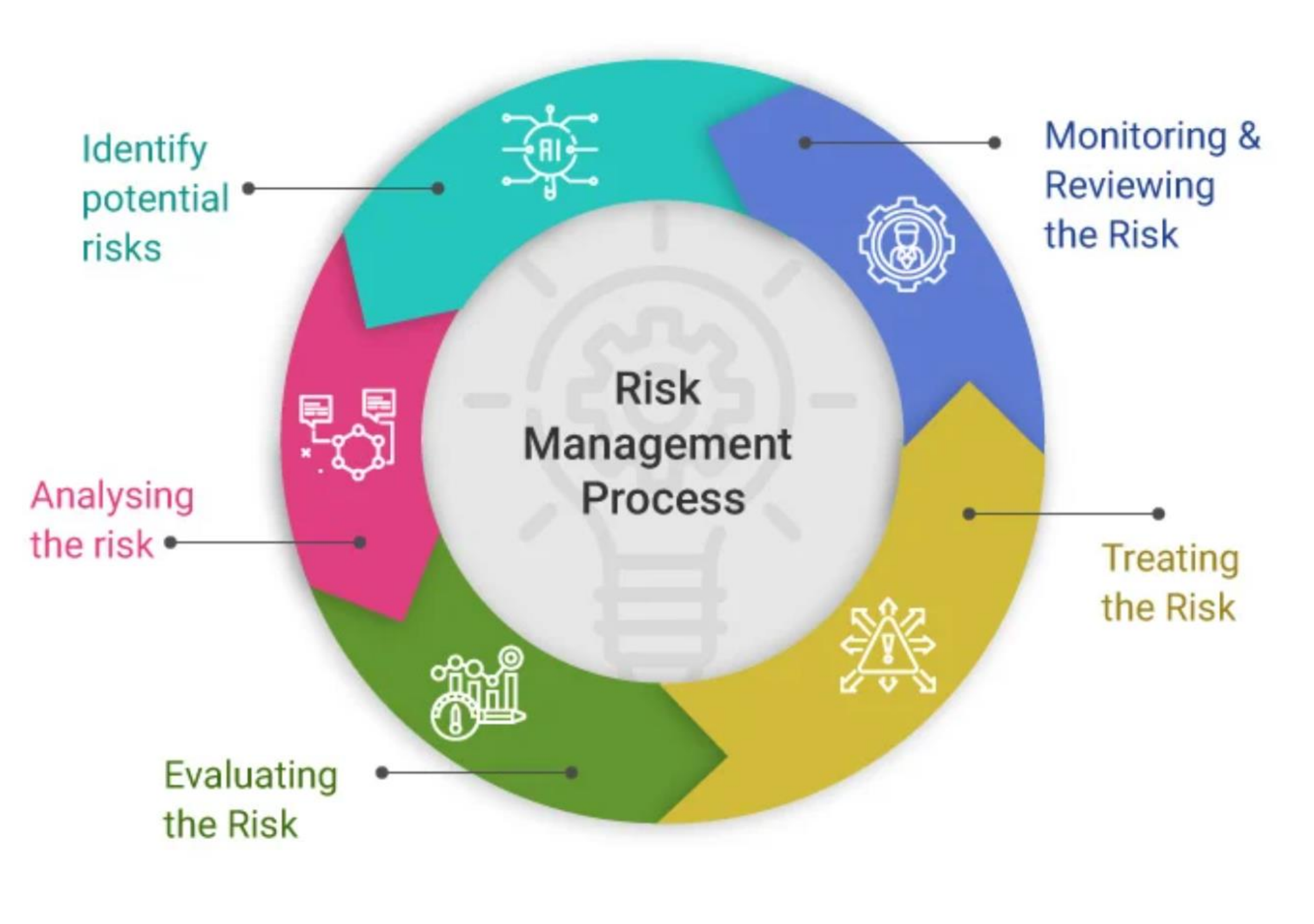
https://www.mdpi.com/2071-1050/12/14/5770

Risk management



https://diceus.com/software-security-risk-management/

Risk management



https://diceus.com/software-security-risk-management/

Organizational Issues

- Chief Security Officer (CSO)
  - Also called chief information security officer (CISO)
- Where to Locate IT Security?
  - Within IT
  - Outside of IT

Identifying the Risk

Identify the type of risk the organization is currently dealing with or could deal with in the future.

Security: Business concern

- Physical assets
- Data/Information assets
- Laws and enforcement in cyber crime

Risk Analysis

- Goal is reasonable risk
- Weighs the probable cost of compromises against the costs of countermeasures
- Also, security has negative side effects that must be weighed

Likelihood

ระดับคะแนน	โอกาสในการเกิดความเสี่ยง (Likelihood)
5	มีโอกาสเกิดสูงมาก
4	มีโอกาสเกิดค่อนข้างสูง
3	มีโอกาสเกิดปานกลาง
2	มีโอกาสเกิดค่อนข้างน้อย
1	มีโอกาสเกิดน้อยมาก

Impact

ระดับคะแนน	ผลกระทบต่อองค์กร (Impact)
5	มีผลกระทบสูงมาก / หายนะ
4	มีผลกระทบค่อนข้างสูง / วิกฤต
3	มีผลกระทบปานกลาง
2	มีผลกระทบค่อนข้างน้อย
1	มีผลกระทบน้อยมาก / ไม่เป็นสาระสำคัญ

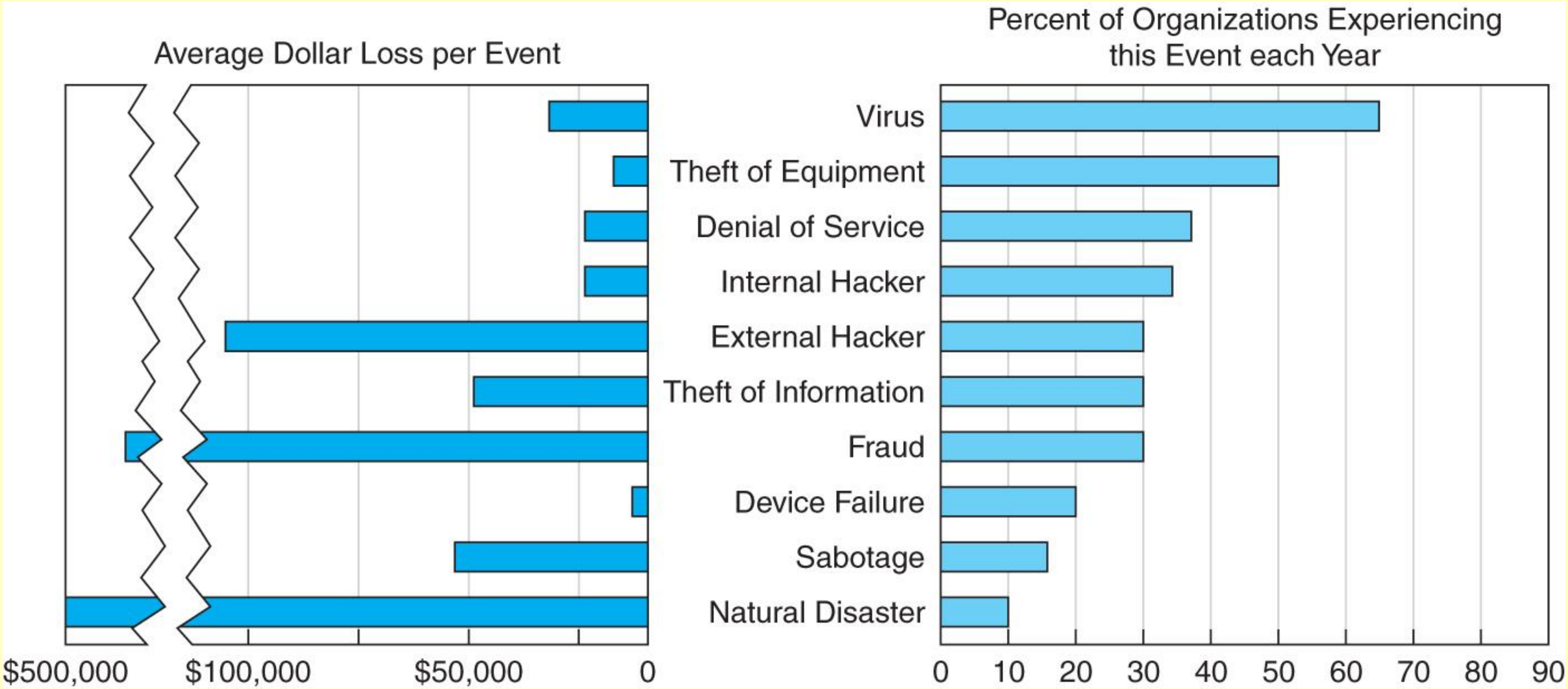
Risk Matrix

Risk Matrix		โอกาสในการเกิดความเสี่ยง (Likelihood)				
		1	2	3	4	5
ผลกระทบต่อองค์กร (Impact)	5	5	10	15	20	25
	4	4	8	12	16	20
	3	3	6	9	12	15
	2	2	4	6	8	10
	1	1	2	3	4	5

Security Threats

- Business continuity planning related threats
  - Disruptions
    - Loss or reduction in network service
    - Could be minor or temporary (a circuit failure)
  - Destructions of data
    - Viruses destroying files, crash of hard disk
  - Disasters (Natural or manmade disasters)
    - May destroy host computers or sections of network
- Intrusion
  - Hackers gaining access to data files and resources
  - Most unauthorized access incidents involve employees
  - Results: Industrial spying; fraud by changing data, etc.

Likelihood and Costs of Threats



Responding to Risk

- Risk Reduction
  - The approach most people consider
  - Install countermeasures to reduce harm
  - Makes sense only if risk analysis justifies the countermeasure
- Risk Acceptance
  - If protecting against a loss would be too expensive, accept losses when they occur
  - Good for small unlikely losses
  - Good for large but rare losses

Responding to Risk

- Risk Transference
  - Buy insurance against security-related losses
  - Especially good for rare but extremely damaging attacks
  - Does not mean a company can avoid working on IT security
  - If bad security, will not be insurable
  - With better security, will pay lower premiums

Responding to Risk

- Risk Avoidance
  - Not to take a risky action
  - Lose the benefits of the action
  - May cause anger against IT security
- Recap: Four Choices When You Face Risk
  - Risk reduction
  - Risk acceptance
  - Risk transference
  - Risk avoidance

Natural Disasters

- tornado
- hurricane
- earthquake
- ice storm / blizzard
- lightning
- flood

Environmental Threats

- inappropriate temperature and humidity
- fire and smoke
- water
- chemical, radiological, biological hazards
- dust
- infestation

Technical Threats

- electrical power is essential to run equipment
  - power utility problems:
    - under-voltage - dips/brownouts/outages, interrupt service
    - over-voltage - surges/faults/lightening, can destroy chips
    - noise - on power lines, may interfere with device operation
- electromagnetic interference (EMI)
  - from line noise, motors, fans, heavy equipment, other computers, nearby radio stations & microwave relays
  - can cause intermittent problems with computers

Human-Caused Threats

- less predictable, may be targeted, harder to deal with
- include:
  - unauthorized physical access
    - leading to other threats
  - theft of equipment / data
  - vandalism of equipment / data
  - misuse of resources

Mitigation Measures
Environmental Threats

- inappropriate temperature and humidity
  - environmental control equipment, power
- fire and smoke
  - alarms, preventative measures, fire mitigation
  - smoke detectors, no smoking
- water
  - equipment location, cutoff sensors
- other threats
  - appropriate technical counter-measures, limit dust entry, pest control

Mitigation Measures
Technical Threats

- electrical power for critical equipment
  - use uninterruptible power supply (UPS)
  - emergency power generator
- electromagnetic interference (EMI)
  - filters and shielding

Mitigation Measures
Human-Caused Threats

- physical access control
  - IT equipment, wiring, power, comms, media
- have a spectrum of approaches
  - restrict building access, locked area, secured, power switch secured, tracking device
- also need intruder sensors / alarms

Recovery from Physical Security Breaches

- redundancy
  - to provide recovery from loss of data
  - ideally off-site, updated as often as feasible
  - can use batch encrypted remote backup
  - extreme is remote hot-site with live data
- physical equipment damage recovery
  - depends on nature of damage and cleanup
  - may need disaster recovery specialists

Governance Frameworks

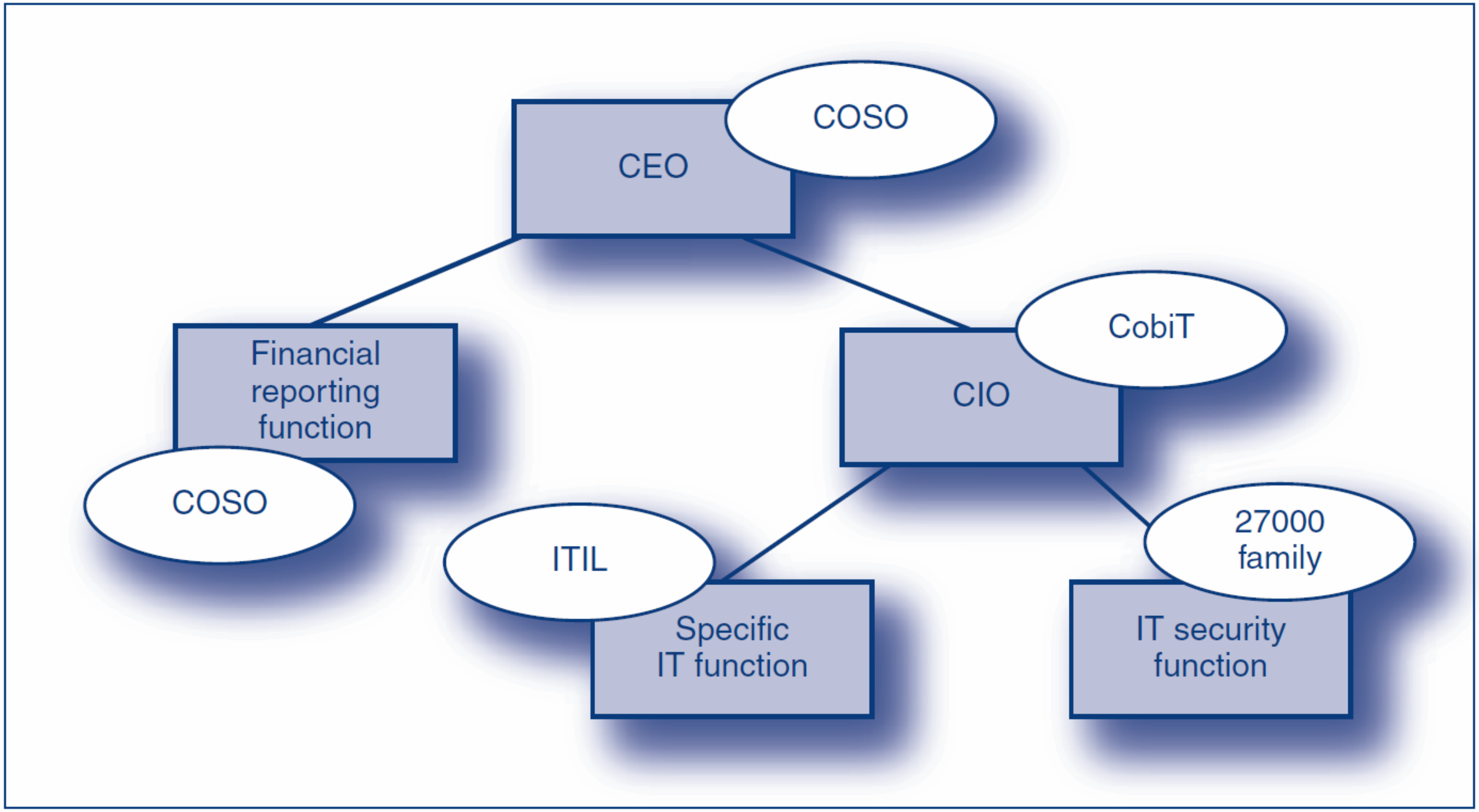


FIGURE 2-25 Governance Frameworks